



آموزش تست نفوذ و رد تیم | TryHackBox

Reconnaissance-Metadata

تهیه شده توسط تیم TryHackBox

کانال های تلگرام ما :

[@TryHackBox](https://t.me/TryHackBox)

[@TryHackBoxOfficial](https://t.me/TryHackBoxOfficial)

[@TryHackBoxStory](https://t.me/TryHackBoxStory)

[@RadioZeroPod](https://t.me/RadioZeroPod)

گیت هاب ما :

<https://github.com/TryHackBox/>

یوتیوب ما :

<https://youtube.com/@tryhackbox>

TryHackBox

سخنی از TryHackBox :

درود دوستان!

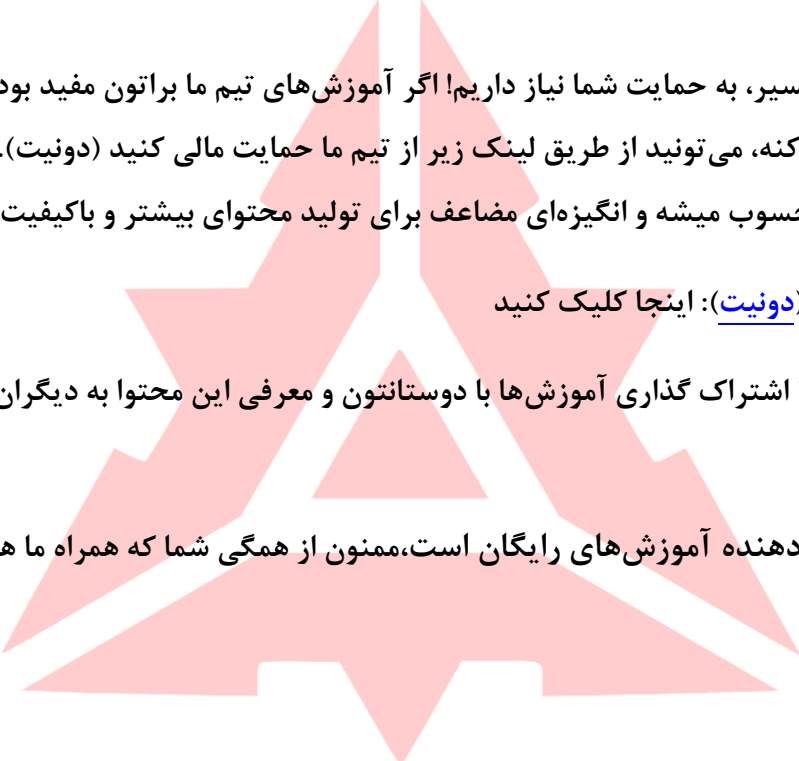
همونطور که می‌دونید، ما به اشتراک گذاری آموزش‌های رایگان در زمینه تست نفوذ و رد تیم (Red Team) تعهد داریم و همیشه سعی می‌کنیم محتوای باکیفیت و کاربردی رو به صورت رایگان در اختیارتون قرار بدیم. هدفمون اینه که دانش امنیت سایبری رو به صورت عادلانه در اختیار همه قرار بدیم، بدون اینکه هزینه‌ای بر دوش شما باشه.

اما برای ادامه این مسیر، به حمایت شما نیاز داریم! اگر آموزش‌های تیم ما براتون مفید بوده و دوست دارید این روند ادامه پیدا کنه، می‌تونید از طریق لینک زیر از تیم ما حمایت مالی کنید (دونیت). هر مقدار، حتی کم، کمک بزرگی محسوب میشه و انگیزه‌ای مضاعف برای تولید محتوای بیشتر و باکیفیت‌تر بهمون میده.

لینک حمایت مالی ([دونیت](#)): اینجا کلیک کنید

همچنین می‌تونید با اشتراک گذاری آموزش‌ها با دوستانتون و معرفی این محتوا به دیگران، ما رو حمایت کنید .

حمایت شما، ادامه‌دهنده آموزش‌های رایگان است، ممنون از همگی شما که همراه ما هستید!


TryHackBox

گام بعدی در شناسایی، تشخیص کاربران سازمان خواهد بود. هدف شناسایی نام‌ها، آدرس‌های ایمیل، نام‌های کاربری و فرمت نام کاربری است. آدرس‌های ایمیل برای فیشینگ بسیار مفید هستند. اگر بتوانیم با استفاده از نام تارگت، ایمیل فیشینگ را شخصی‌سازی کنیم، موفقیت آن بیشتر خواهد شد. همچنین از نام‌ها و آدرس‌های ایمیل می‌توان برای تهیه فهرست نام‌های کاربری استفاده کرد که در حملات حدس زدن رمز عبور بسیار کمک‌کننده است.

متادیتا (Metadata)

متادیتا، داده‌ای درباره خود داده است.

هنگامی که سازمان‌ها اسناد را ایجاد می‌کنند، نرم‌افزارهای مورد استفاده برای ایجاد این اسناد، حجم عظیمی از اطلاعات را در فایل‌های سند جاسازی می‌کنند. طبیعتاً بخش عمده‌ای از این اطلاعات، محتوای خود فایل است. اما مقدار قابل توجهی متادیتا (یعنی داده‌هایی درباره داده‌های دیگر یا داده‌هایی که داده‌های دیگر را توصیف می‌کنند) نیز در فایل گنجانده شده است.

بسیاری از ابزارهای ایجاد و ویرایش فایل‌ها، ورودی‌های متادیتا اضافی را شامل می‌شوند که می‌توانند برای تست‌های نفوذ مفید باشند، از جمله:

- **نام‌های کاربری:** اغلب برای حملات حدس زدن رمز عبور کاربران و اکسپلویت‌ها استفاده می‌شوند.
- **مسیرهای سیستم فایل:** این به پنتستر کمک می‌کند بداند داده‌های مهم در سازمان کجا ذخیره شده‌اند و همچنین می‌تواند قراردادهای نام‌گذاری سیستم و حتی دایرکتوری‌های مهم را نشان دهد.
- **آدرس‌های ایمیل:** برای فیشینگ و حدس زدن رمز عبور مفید هستند.
- **نرم‌افزارهای سمت کلاینت مورد استفاده:** برای اکسپلویت سمت کلاینت مفیدند، به ویژه وقتی سند جدید است و شامل اطلاعات نسخه نرم‌افزار می‌باشد.
- **اطلاعات دیگر:** اغلب اطلاعات مفید دیگری مرتبط با محتوای سند وجود دارد که روی صفحه نمایش داده نمی‌شود، مانند اطلاعات undo، نسخه‌های قبلی، و اطلاعات مخفی یا پنهان شده (مثل ستون‌های مخفی در صفحه‌گسترده یا متن حیاتی در سند که زیر یک تصویر پنهان شده است).

متادیتا در انواع اسناد

تقریباً هر نوع سندی حاوی نوعی از متادیتا است، اما برخی از اسناد از نظر متادیتا غنی‌تر از سایرین هستند. انواع اسناد زیر که توسط اکثر سازمان‌ها تولید و استفاده می‌شوند، به‌ویژه برای پنتسترها جالب توجه هستند:

1. فایل‌های PDF

این فایل‌ها با نرم‌افزار Acrobat Reader و سایر ابزارهای ایجاد و ویرایش PDF مرتبط هستند و معمولاً حاوی متادیتا ارزشمندی می‌باشند.

2. فایل‌های مایکروسافت آفیس

شامل انواع فرمت‌های:

- Word (doc, docx, dotx, docm)
- Excel (xls,xlsx, xslt, xslm)
- PowerPoint (ppt, pot, pptx, ptm)

این اسناد که با مجموعه نرم‌افزاری آفیس ایجاد می‌شوند، معمولاً حاوی حجم قابل توجهی متادیتا هستند.

3. فایل‌های HTML و HTM

این فایل‌ها که حاوی صفحات وب هستند، ممکن است در نگاه اول بی‌اهمیت به نظر برسند. اما:

- کامنت‌ها و المان‌های فرم مخفی در آن‌ها ممکن است حاوی متادیتا مفیدی برای تست نفوذ باشند.
- کامنت‌های موجود در کدهای HTML یا JavaScript ممکن است اطلاعات حساس یا ویژگی‌های مستند نشده برنامه‌های وب را فاش کنند.

اسناد دیگر

علاوه بر این انواع اسناد، صدها نوع سند دیگر وجود دارند که ممکن است حاوی اطلاعات ارزشمندی باشند. این فهرست به هیچ وجه کامل نیست، بلکه صرفاً برای آشنایی خواننده با انواع اسناد جالب و مفید جهت تحلیل در طول تست نفوذ طراحی شده است.

انواع اسناد با متادیتای ارزشمند برای تست نفوذ

1. فایل‌های طراحی و مهندسی

- AutoCAD (DWG, DXF) ← شامل نام طراح و مشخصات پروژه
- Revit (RVT) ← اطلاعات ساختمان هوشمند

2. فایل‌های رسانه‌ای

- تصاویر ← (JPEG, PNG) EXIF داده (مختصات GPS، مدل دوربین)
- ویدئوها (MP4, MOV) ← metadata دوربین و تاریخ‌های ضبط

3. اسناد فشرده

- ZIP/RAR ← ساختار دایرکتوری داخلی و نام‌های کاربری
- 7z ← تاریخچه فشرده‌سازی

4. اسناد متنی

- TXT/RTF ← اطلاعات ویرایشگر
- Markdown ← تاریخچه commits (اگر از Git استفاده شده)

5. فایل‌های سیستمی

- لاگ‌ها (LOG) ← خطاهای سیستم و نام کاربری‌ها
- پیکربندی (CFG, INI) ← تنظیمات حساس

نکات طلایی برای تستر نفوذ

1. ابزارهای ضروری:

- ExifTool (برای همه فرمت‌ها)
- Binwalk (برای آنالیز فایل‌های باینری)

2. تکنیک جستجو:

- `exiftool -r /path/to/files`

• دفاع سازمانی:

- پیاده‌سازی DLP (Data Loss Prevention)
- آموزش کارکنان درباره خطرات اشتراک اسناد خام

استخراج اسناد برای تحلیل متادیتا

برای انجام تحلیل متادیتا، یک پنتستر ابتدا باید فایل‌ها را برای تحلیل بازیابی کند. روش‌های متعددی را می‌توان برای جمع‌آوری این اسناد به کار برد. یکی از رایج‌ترین و به ویژه مهم‌ترین روش‌ها برای جمع‌آوری اسناد جهت تحلیل متادیتا، استفاده از ابزار وب اسپایدر علیه وبسایت سازمان تارگت است که تمام اسناد بالقوه جالب را برای تحلیل روی ماشین پنتستر دانلود می‌کند.

در آزمایش بعدی، نحوه استفاده از ابزار wget برای این منظور را بررسی خواهیم کرد. می‌توانیم از ابزاری مانند PowerMeta ساخته Beau Bullock برای پیدا کردن داده در موتورهای جستجو، دانلود فایل‌ها و انجام تحلیل متادیتا

استفاده کنیم. PowerMeta در آدرس <https://github.com/daftHack/PowerMeta> در دسترس است. پنتستر ممکن است پیش از این در مرحله برنامه‌ریزی پروژه تست، برخی اسناد تولید یا ویرایش شده توسط پرسنل سیستم تارگت را دریافت کرده باشد. برای مثال، پنتستر ممکن است قراردادهای قواعد Engagement، اطلاعات محدوده، دیاگرام‌ها، قراردادهای عدم افشا، قراردادهای خط‌مشی‌ها و رویه‌ها و سایر اطلاعات را دریافت کرده باشد. و در نهایت، اگر تست نفوذ توسط پنتسترهای داخلی (کارمندان همان سازمان تارگت) انجام شود، آنها معمولاً می‌توانند مقدار زیادی از اسناد را برای تحلیل از سرورهای فایل سازمان تهیه کنند. ابزارهای زیادی برای استخراج متادیتا وجود دارد که رایج‌ترین آنها عبارتند از:

- ExifTool
- FOCA <https://www.elevenpaths.com/labstools/foca/index.html>
- ابزار استخراج متادیتا از وزارت امور داخلی نیوزیلند <https://github.com/DIA-NZ/Metadata-Extraction-Tool>

نکات طلایی برای پنتسترها

اولویت‌بندی اسناد:

ابتدا PDF، Word، Excel ← بیشترین متادیتا

سپس فایل‌های مهندسی و رسانه‌ای

دستور مفید ExifTool

`exiftool -a -G1 -s -ee FILE`

TryHackBox

دفاع سازمانی:

پاک‌سازی متادیتا قبل از اشتراک‌گذاری

محدود کردن دسترسی به اسناد حساس

ExifTool

ابزار ExifTool بر روی خواندن، نوشتن یا ویرایش متادیتا در بیش از ۱۰۰ نوع فایل مختلف تمرکز دارد، از جمله تصاویر، فایل‌های صوتی، ویدیوها، اسناد آفیس (doc, dot, xls, ppt و بیشتر)، فایل‌های PDF و تعداد زیادی از فرمت‌های دیگر. این ابزار توسط Phil Harvey نوشته شده و به صورت رایگان برای ویندوز، مک اواس و لینوکس منتشر شده است.

در اولین انتشار، تمرکز اصلی ExifTool بر روی فایل‌های تصویری و صوتی بود. برای تصاویر، این ابزار بر استخراج نوع دوربین و جزئیات مربوط به فرمت تصویر تمرکز داشت. همچنین اطلاعاتی درباره ابزارهای مورد استفاده برای ویرایش تصویر یا صدا را استخراج میکرد. اگر تصویر حاوی geotags باشد که عرض و طول جغرافیایی محل گرفته شدن عکس را نشان میدهند، ExifTool این اطلاعات را بازیابی می‌کند.

ExifTool به طور قابل توجهی فراتر از ریشه‌های اولیه خود در متادیتای تصاویر و صدا گسترش یافته و اکنون داده‌ها را از اکثر فرمت‌های فایلی که یک پنتستر احتمالاً با آنها مواجه میشود استخراج میکند. از جمله موارد مورد علاقه پنتسترها، قابلیت ExifTool در تشخیص نام‌های کاربری، آدرس‌های ایمیل و ابزارهای ویرایش سند از فایل‌هایی است که تحلیل میکند.

به طور پیشفرض، ExifTool یک یا چند فایل ارائه شده در خط فرمان را پردازش میکند. همچنین میتواند کل دایرکتوری‌ها را در ماشین محلی که روی آن اجرا میشود پردازش کند، تمام فایل‌های موجود در دایرکتوری را بررسی کند و حتی میتواند به صورت بازگشتی در ساختار دایرکتوری جستجو کرده و تمام فایل‌های پیدا شده را تحلیل کند.

ابزار PowerMeta که قبلاً ذکر شد از ExifTool برای استخراج متادیتا از فایل‌های بازیابی شده استفاده میکند.

TryHackBox

جزئیات دستور Strings

برخلاف بسیاری از ابزارهای تحلیل متادیتا که بر داده‌های ساختاریافته تمرکز می‌کنند، دستور strings برای پیدا کردن داده‌های غیرساختاریافته یا داده‌هایی با ساختار ناشناخته مفید است. دستور strings به سادگی متن قابل چاپ را از فایل‌ها نمایش می‌دهد. این دستور در اکثر توزیع‌های لینوکس و انواع یونیکس وجود دارد. برای ویندوز نیز این دستور به صورت یک دانلود جداگانه در بسته‌های مختلف موجود است. به عنوان مثال، این دستور به عنوان بخشی از Cygwin (محیط رایگان POSIX برای ویندوز) در آدرس www.cygwin.com موجود است. یا به صورت یک دانلود مستقل رایگان از Microsoft Sysinternals قابل دسترسی است.

به طور پیش فرض، نسخه لینوکس strings فقط به دنبال رشته‌های ASCII قابل چاپ می‌گردد. این دستور فایل را برای یافتن چهار یا چند کاراکتر ASCII متوالی جستجو کرده و سپس آن‌ها را به خروجی استاندارد چاپ می‌کند. برای تغییر طول حداقل رشته پیش فرض، می‌توان از گزینه n استفاده کرد تا طول مورد نظر کاربر (X) مشخص شود. مقدار پیش فرض چهار کاراکتر برای اکثر موارد مناسب است.

بسیاری از انواع اسناد، به ویژه آن‌هایی که با برنامه‌های Microsoft Office مرتبط هستند (مانند doc, docx, xls, xlsx و ...) برخی رشته‌ها را نه به صورت ASCII (نمایش 8 بیتی کاراکترها) بلکه به صورت Unicode (نمایش 16 بیتی کاراکترها) ذخیره می‌کنند. اگر در لینوکس از strings با تنظیمات پیش فرض استفاده کنید، فقط رشته‌های ASCII را نشان خواهد داد و ممکن است برخی اطلاعات بسیار مفید را از دست بدهید. بهتر است چندین بار از strings استفاده کنید: یک بار با تنظیمات پیش فرض ASCII، یک بار با گزینه e (برای نوع "رمزگذاری" کاراکترهای 16 بیتی big-endian) و یک بار با $1-e$ (حرف کوچک "L"، برای رمزگذاری 16 بیتی Big endian). Big endian و little endian به ترتیب بایت‌ها برای رشته مورد نظر در فایل اشاره دارند. اکثر ابزارهای ویرایش اسناد مایکروسافت از رمزگذاری little-endian استفاده می‌کنند اما گاهی اوقات (حتی در همان فایل) برخی رشته‌ها را به صورت big-endian ذخیره می‌کنند.

نسخه Sysinternals از strings به طور پیش فرض به دنبال رشته‌های ASCII، Unicode با ترتیب big-endian و Unicode با ترتیب little-endian می‌گردد (هر سه فرمت مختلف را در یک فراخوانی جمع‌آوری می‌کند) و بر رشته‌های با طول سه کاراکتر یا بیشتر تمرکز دارد. برای تمرکز فقط بر روی ASCII یا Unicode، می‌توان به ترتیب از گزینه‌های a یا u استفاده کرد. و برای تغییر حداقل طول کاراکتر، می‌توان از n استفاده نمود.

"سندی که امروز بی خطر به نظر می‌رسد، فردا ممکن است کلید نفوذ به شبکه

شما باشد!"

TryHackBox